Университетская лабораторная работа

Отчет по лабораторной работе № 2

Формирование требований безопасности к программной системе

Дисциплина:	Основы разработки защищенного программного обеспечения и компьютерных сетей
Вариант:	19 — Система учета транспортных средств организации
Исходная версия:	v0.1
Версия ЛР:	v0.2
Студент:	Мостовая Полина Андреевна
Группа:	ИУСбд-02-23

2026

Содержание

1 Цель работы 2

2 Назначение и границы системы 2
2.1 Роли 2
2.2 Функции 3
2.3 Категории обрабатываемых данных 3

3 Активы и их значимость 4

4 Предварительная матрица доступа 6

5 Требования безопасности 7

6 Сценарии приемки 10
6.1 Прослеживаемость 11

7 Согласованность и результаты проверок 12

8 Проверка Git 13

9 Ответы на контрольные вопросы 17

10 Вывод 18

Список использованных источников 19

1. Цель работы

Цель работы — определить, какие данные и функции системы нужно защищать, кому они доступны и как проверять требования безопасности. Эта лабораторная продолжает проект, начатый в работе № 1. Основной результат — проектная документация; механизмы защиты будут разрабатываться позднее [1].

2. Назначение и границы системы

Система учета транспортных средств организации предназначена для ведения реестра автопарка, закрепления транспорта за водителями, планирования поездок, учета пробега и контроля технического состояния. Она нужна, чтобы сведения об использовании служебного транспорта хранились и обновлялись в одном месте.

В границы проекта входят приложение, база данных, конфигурация и журнал событий. Кадровая система может быть источником профилей, но интеграция с ней в проект не входит. Система не управляет движением транспорта и не определяет его местоположение. Для учебных проверок используются искусственные данные.

Сейчас приложение загружает и проверяет конфигурацию, затем выводит стартовое сообщение. Интерфейса, базы данных и учета транспорта и поездок пока нет; вход пользователей, разграничение доступа и журналирование также не реализованы.

На снимке показан фактический результат запуска приложения.

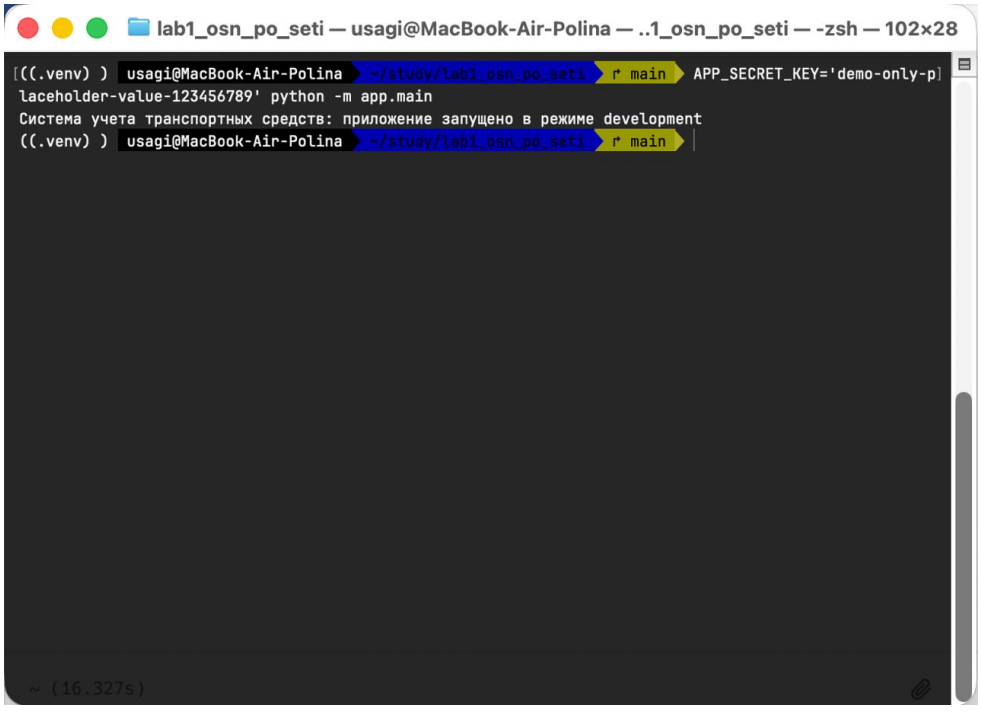


Рис. 1: Запуск приложения и стартовое сообщение

2.1. Роли

Водитель Просматривает только закрепленные транспортные средства и собственные назначенные поездки, передает пробег и сведения о неисправностях.

Диспетчер Ведет карточки транспорта, назначает транспорт, планирует поездки, учитывает техническое состояние и обслуживание.

Руководитель Просматривает агрегированные учетные отчеты без деталей маршрутов.

Администратор Управляет учетными записями, ролями и настройками, просматривает журнал безопасности. Автоматического доступа ко всем поездкам у него нет.

Неаутентифицированный пользователь Может обратиться только к форме входа; данные и остальные операции ему недоступны.

2.2. Функции

Функции F-1–F-8 являются проектируемыми: вход, просмотр и изменение карточек, назначения, поездки, учет технического состояния, отчеты и журнал событий. Загрузка и проверка конфигурации (F-9), а также вывод стартового сообщения (F-10) уже реализованы.

ID	Функция	Пользователь	Основные данные	Состояние
F-1	Вход и проверка учетных данных	Все роли	Идентификатор входа, данные проверки	Запланирована
F-2	Просмотр карточек транспорта	Водитель, диспетчер	Госномер, модель, статус	Запланирована
F-3	Создание и изменение карточек ТС	Диспетчер	Карточка ТС, статус	Запланирована
F-4	Назначение ТС и планирование поездок	Диспетчер	Водитель, ТС, дата, маршрут	Запланирована
F-5	Регистрация поездки, пробега и неисправности	Водитель, диспетчер	Поездка, пробег, результат	Запланирована
F-6	Учет состояния и обслуживания	Диспетчер	Статус ТС, дефект, работы, срок ТО	Запланирована
F-7	Формирование учетных отчетов	Диспетчер; руководитель читает сводку	Автопарк, поездки, обслуживание	Запланирована
F-8	Журналирование действий и событий безопасности	Администратор	Субъект, действие, время, результат	Запланирована
F-9	Загрузка и проверка конфигурации	Администратор среды	APP_NAME, APP_ENV, APP_SECRET_KEY	Реализована
F-10	Вывод стартового сообщения без секрета	Запускающий приложение	Название, режим работы	Реализована

2.3. Категории обрабатываемых данных

ID	Категория	Примеры полей	Источник и хранение	Ограничение доступа
DT-1	Профили пользователей	Имя, табельный номер, контакт	Администратор; база данных (планируется)	Собственный профиль; администратору только нужные поля
DT-2	Учетные данные и роли	Идентификатор, хэш пароля, роль	Пользователь или администратор; база данных (планируется)	Проверочные данные не отображаются; роль меняет администратор
DT-3	Конфигурация	Режим, секретный параметр	Администратор среды; окружение или локальный .env	Только обслуживающий субъект; секрет не выводится
DT-4	Карточки транспорта	Госномер, модель, статус	Диспетчер; база данных (планируется)	Диспетчер по автопарку; водитель по закреплению
DT-5	Назначения и поездки	Водитель, ТС, маршрут, пробег	Диспетчер и водитель; база данных (планируется)	Диспетчер по задаче; водитель только по своим поездкам
DT-6	Техническое состояние	Дефект, работы, сроки ТО	Водитель сообщает, диспетчер учитывает; база данных (планируется)	Диспетчер изменяет запись; водитель сообщает о дефекте
DT-7	Журналы и отчеты	Действие, время, результат, сводные показатели	Приложение и диспетчер; журнал и база данных (планируются)	Журнал — администратору; руководителю — агрегированные отчеты

3. Активы и их значимость

Оценки даны по шкале 1–3: 1 — низкая, 2 — средняя, 3 — высокая значимость. C_i — конфиденциальность, I_i — целостность, A_i — доступность. $K_i = \max(C_i, I_i, A_i)$ показывает наибольшую оценку, но не является оценкой риска.

ID	Актив	Ответственный	C_i	I_i	A_i	K_i	Обоснование оценок
AS-1	Учетные записи и данные проверки пароля	Администратор безопасности	3	3	3	3	Раскрытие может открыть учетные записи; подмена нарушает идентификацию; без входа пользователи не работают.
AS-2	Профили и роли	Администратор безопасности	2	3	2	3	Раскрываются служебные сведения; неверная роль меняет полномочия; восстановление профилей требует ручной работы.
AS-3	Секрет и конфигурация приложения	Администратор среды	3	3	2	3	Раскрытие ослабляет защиту; подмена меняет режим; конфигурацию можно восстановить из защищенного источника.
AS-4	Реестр транспорта	Владелец процесса учета автопарка	2	3	3	3	Искажение карточек нарушает учет; недоступность останавливает основную функцию.
AS-5	Назначения и поездки	Владелец диспетчеризации	3	3	3	3	Маршруты связаны с сотрудниками; подмена нарушает учет; потеря доступа блокирует диспетчеризацию.
AS-6	Техническое состояние и обслуживание	Ответственный за технический учет	2	3	3	3	Неверный статус влияет на эксплуатационные решения; недоступность мешает контролю исправности.
AS-7	Журнал событий безопасности	Ответственный за контроль безопасности	2	3	2	3	Подмена мешает разбору событий; краткая недоступность допускает отложенный анализ.
AS-8	Учетные отчеты	Владелец процесса учета автопарка	2	3	2	3	Искажение влияет на решения; отчет можно восстановить из первичных данных.
AS-9	Исходный код и тесты	Разработчик проекта	1	3	2	3	Подмена может внести дефекты; исходники восстанавливаются из Git.
AS-10	Работоспособность системы	Владелец сервиса	1	2	3	3	Длительная остановка блокирует основные операции; краткий сбой не искажает сохраненные данные.

Активы пока проектируются. Сейчас приложение только загружает конфигурацию и проверяет длину значения секретного ключа; криптографически ключ не используется.

4. Предварительная матрица доступа

Неаутентифицированный пользователь может открыть форму входа, но не получает данные. Явно не разрешенные действия запрещены. Роли не наследуются. Для водителя проверяется принадлежность поездки/транспорта; руководитель видит только агрегированные отчеты. Администратор не получает автоматического доступа к маршрутам. Эти правила соответствуют рекомендациям OWASP проверять полномочия для каждого запроса и придерживаться минимальных привилегий [3].

Операция	Без входа	Водитель	Диспетчер	Руководитель	Администратор
Форма входа	Разрешено, без выдачи данных	Разрешено	Разрешено	Разрешено	Разрешено
Просмотр карточки ТС	Запрещено	Только закрепленное ТС	Весь автопарк по задаче	Запрещено	Запрещено, кроме минимальных полей для учетной записи
Создать/изменить карточку ТС	Запрещено	Запрещено	Разрешено	Запрещено	Запрещено
Просмотр маршрута	Запрещено	Только собственная назначенная поездка	По автопарку в рамках работы	Запрещено	Запрещено по умолчанию
Изменение назначения	Запрещено	Запрещено	Разрешено	Запрещено	Запрещено
Передача отчета о неисправности	Запрещено	Только по своей поездке	В рамках учета	Запрещено	Запрещено
Изменение обслуживания	Запрещено	Запрещено; можно сообщить о дефекте	Разрешено	Запрещено	Запрещено
Просмотр учетного отчета	Запрещено	Запрещено	По служебной задаче	Только агрегированные показатели	Запрещено по умолчанию
Учетные записи и роли	Запрещено	Запрещено	Запрещено	Запрещено	Разрешено по процедуре
Просмотр журнала безопасности	Запрещено	Запрещено	Запрещено	Запрещено	Разрешено в рамках обязанностей безопасности

Матрица описывает планируемую политику и пока не реализована в коде.

5. Требования безопасности

Подготовлено 13 требований: восемь функциональных, три нефункциональных и два процессных. Приоритет для каждого — обязательный. Далее приведены критерии, способы проверки и текущие статусы.

SEC-1. Доступ после аутентификации

Тип. Функциональное.

Активы. AS-1, AS-2, AS-4–AS-8.

Обоснование. Не допустить анонимный доступ к сведениям о сотрудниках, транспорте и поездках.

Критерий. Анонимный запрос защищенной функции отклонен; содержимое не возвращается, данные не меняются.

Проверка. Негативный интеграционный сценарий AT-1 и тест успешного входа.

Статус. Сформулировано.

SEC-2. Проверка полномочий по роли

Тип. Функциональное.

Активы. AS-2, AS-4–AS-8.

Обоснование. Предотвратить действия вне служебных полномочий.

Критерий. Разрешенная операция выполнена; запрещенная отклонена без изменения данных.

Проверка. Тесты ролей по матрице доступа; сценарии AT-3–AT-6.

Статус. Сформулировано.

SEC-3. Доступ водителя к назначенным данным

Тип. Функциональное.

Активы. AS-2, AS-4, AS-5.

Обоснование. Ограничить раскрытие чужих поездок и назначений.

Критерий. Собственная поездка доступна; запрос чужой поездки отклоняется без выдачи полей и изменения данных.

Проверка. Пара AT-3/AT-4 с двумя водителями.

Статус. Сформулировано.

SEC-4. Изменение карточки транспортного средства

Тип. Функциональное.

Активы. AS-4.

Обоснование. Защитить целостность реестра.

Критерий. Диспетчер сохраняет изменение; водитель и администратор получают отказ, карточка остается прежней.

Проверка. Тест ролей и проверка записи до и после запроса.

Статус. Сформулировано.

SEC-5. Изменение назначения и плана поездки

Тип. Функциональное.

Активы. AS-2, AS-5.

Обоснование. Сохранить правильность планирования и закрепления транспорта.

Критерий. Изменение диспетчера сохраняется; запрос другой роли отклонен, назначение не меняется.

Проверка. Интеграционные тесты ролей и состояния записи.

Статус. Сформулировано.

SEC-6. Проверка отчета о поездке

Тип. Функциональное.

Активы. AS-2, AS-5.

Обоснование. Ограничить подмену чужих отчетов и ошибочные значения пробега.

Критерий. Корректный пробег своей поездки сохраняется; отрицательный пробег или чужая поездка отклоняются без создания/изменения отчета.

Проверка. Позитивный и негативный сценарии AT-5 и AT-6.

Статус. Сформулировано.

SEC-7. Журналирование значимых действий

Тип. Функциональное.

Активы. AS-1, AS-2, AS-5, AS-7.

Обоснование. Сохранить сведения для последующего разбора действий.

Критерий. Для тестового изменения и отказа созданы записи с субъектом, действием, временем и результатом.

Проверка. Проверить журнал после успешной и отклоненной операции.

Статус. Сформулировано.

SEC-8. Доступ к журналу безопасности

Тип. Функциональное.

Активы. AS-2, AS-7.

Обоснование. Ограничить раскрытие истории действий сотрудников.

Критерий. Администратор безопасности получает журнал; водитель и диспетчер не видят его содержимое.

Проверка. Тест доступа к журналу для каждой роли.

Статус. Сформулировано.

SEC-9. Отсутствие секрета в выводе

Тип. Нефункциональное.

Активы. AS-3, AS-9.

Обоснование. Не раскрывать секрет через консольные сообщения.

Критерий. При штатном запуске и предусмотренных ошибках тестовое значение секрета отсутствует в stdout/stderr.

Проверка. Захват stdout/stderr с искусственным секретом.

Статус. Реализовано частично: стартовое сообщение не включает секрет; штатный вывод покрыт тестами, вывод ошибок отдельно не проверялся.

SEC-10. Проверка конфигурации до запуска

Тип. Нефункциональное.

Активы. AS-3, AS-10.

Обоснование. Не допустить запуск в неопределенном режиме.

Критерий. Пустое имя, неизвестная среда или ключ короче 32 символов приводят к контролируемой ошибке до старта.

Проверка. Тесты конфигурации для трех ошибочных значений; анализ кода.

Статус. Реализовано: проверки есть в app/config.py; отдельные автоматические тесты не добавлены.

SEC-11. Защита сетевой передачи

Тип. Нефункциональное.

Активы. AS-1, AS-5, AS-10.

Обоснование. Снизить риск перехвата учетных данных и поездок.

Критерий. После появления сетевого интерфейса тестовое развертывание использует TLS и не принимает учетные данные по незащищенному каналу.

Проверка. Проверка конфигурации развертывания и сетевое испытание.

Статус. Сформулировано; сетевого интерфейса пока нет.

SEC-12. Проверка изменений до выпуска

Тип. Процессное.

Активы. AS-9, AS-1–AS-8.

Обоснование. Снизить вероятность внесения дефектов в проект и защитные механизмы.

Критерий. Для изменения имеются результат ревью и результаты применимых тестов до включения в релиз.

Проверка. Анализ истории изменений и протокола проверок.

Статус. Сформулировано.

SEC-13. Работа с секретами в Git

Тип. Процессное.

Активы. AS-3, AS-9.

Обоснование. Не допустить публикацию реальных секретов.

Критерий. Файл .env не отслеживается, staged diff не содержит реальных секретов, шаблон содержит условное значение.

Проверка. git ls-files .env; проверка .env.example и staged diff.

Статус. Реализовано частично: файл исключен, шаблон существует; diff требуется проверять перед фиксацией.

6. Сценарии приемки

Сценарии описывают ожидаемое поведение функций, которые пока не реализованы. Ни один сценарий не выполнялся. Их критерии соотносятся с проверяемыми требованиями OWASP ASVS [2].

AT-1 — Негативный: анонимный запрос карточки ТС

Исходные условия. Система запущена; пользователь не вошел; существует карточка ТС-001.

Тестовые данные. Запрос карточки ТС-001 без учетных данных.

Действия. Открыть адрес карточки, записать ответ, затем проверить карточку уполномоченной тестовой учетной записью.

Ожидаемый ответ. Запрос отклонен или перенаправлен на вход; поля карточки не раскрываются.

Ожидаемое состояние данных. Карточка не меняется; новые поездки и назначения не создаются.

Статус. Сформулировано, не выполнено.

AT-2 — Позитивный: успешный вход

Исходные условия. Учетная запись DRV-001 активна.

Тестовые данные. Искусственные действительные учетные данные DRV-001.

Действия. Отправить данные форме входа; открыть профиль водителя.

Ожидаемый ответ. Вход принят; доступны только данные, разрешенные роли.

Ожидаемое состояние данных. Роль и учетные данные не меняются; секрет проверки клиенту не возвращается.

Статус. Сформулировано, не выполнено.

AT-3 — Позитивный: чтение назначенной поездки

Исходные условия. DRV-001 вошел; TRIP-001 назначена ему и связана с ТС-001.

Тестовые данные. DRV-001, TRIP-001, ТС-001.

Действия. Водитель запрашивает TRIP-001 и сверяет показанные дату и статус.

Ожидаемый ответ. Сведения собственной поездки возвращены.

Ожидаемое состояние данных. Чтение не меняет поездку или назначение.

Статус. Сформулировано, не выполнено.

AT-4 — Негативный: запрос чужой поездки

Исходные условия. DRV-001 и DRV-002 существуют; TRIP-002 назначена DRV-002, статус «Запланирована».

Тестовые данные. DRV-001 запрашивает TRIP-002.

Действия. Войти как DRV-001; запросить TRIP-002; проверить запись от диспетчера.

Ожидаемый ответ. Отказ без раскрытия маршрута, пробега и деталей.

Ожидаемое состояние данных. Статус и назначенный водитель не изменились.

Статус. Сформулировано, не выполнено.

AT-5 — Позитивный: допустимый пробег

Исходные условия. DRV-001 вошел; TRIP-001 назначена ему; начальный пробег 12400 км.

Тестовые данные. Конечный пробег 12525 км; результат поездки заполнен.

Действия. Открыть свою поездку; внести пробег и результат; отправить отчет; прочитать запись.

Ожидаемый ответ. Отчет принят.

Ожидаемое состояние данных. Отчет с пробегом 12525 км связан с TRIP-001; чужие записи не меняются.

Статус. Сформулировано, не выполнено.

AT-6 — Негативный: пробег ниже исходного

Исходные условия. DRV-001 вошел; TRIP-001 назначена ему; начальный пробег 12400 км.

Тестовые данные. Конечный пробег 12300 км.

Действия. Отправить отчет; зафиксировать ответ; повторно прочитать поездку и отчет.

Ожидаемый ответ. Отчет отклонен с сообщением о недопустимом пробеге.

Ожидаемое состояние данных. Отчет не создан, прежний пробег не изменен.

Статус. Сформулировано, не выполнено.

6.1. Прослеживаемость

Активы	Функция	Требование	Проверка
AS-1, AS-2, AS-4–AS-8	F-1, F-2	SEC-1	AT-1, AT-2
AS-2, AS-4, AS-5	F-2, F-5	SEC-3	AT-3, AT-4

Активы	Функция	Требование	Проверка
AS-2, AS-5	F-5	SEC-6	AT-5, AT-6
AS-2, AS-4–AS-8	F-1–F-8	SEC-2	Тесты ролей по матрице
AS-4	F-3	SEC-4	Тест ролей и состояния карточки
AS-2, AS-5	F-4	SEC-5	Тест полномочий и назначения
AS-1, AS-2, AS-5, AS-7	F-8	SEC-7	Проверка журнала после разрешенной и отклоненной операции
AS-2, AS-7	F-8	SEC-8	Тест чтения журнала по ролям
AS-3, AS-9	F-9, F-10	SEC-9	Захват вывода с тестовым секретом
AS-3, AS-10	F-9	SEC-10	Проверки некорректной конфигурации
AS-1, AS-5, AS-10	F-1, F-5	SEC-11	Конфигурация TLS и сетевое испытание после реализации API
AS-9, AS-1–AS-8	F-1–F-8	SEC-12	Проверка ревью и результатов тестов
AS-3, AS-9	F-9	SEC-13	git ls-files .env, шаблон и staged diff

7. Согласованность и результаты проверок

В документах используется единая система идентификаторов. Матрица содержит все роли, а права на поездки и транспорт ограничены принадлежностью объекта. Сценарии связаны с требованиями; тестовые результаты для будущих функций не заявляются.

В проекте определены четыре аутентифицированные роли и неаутентифицированный пользователь, десять функций, семь категорий данных, десять активов, десять операций матрицы, тринадцать требований и шесть сценариев (три позитивных и три негативных). У каждого требования указаны все необходимые поля. Оценки активов находятся в диапазоне 1–3; для каждого приведены Ci, Ii, Ai, Ki и обоснование.

Три исходных автоматических теста выполнены успешно: 3 passed. Они проверяют только стартовое сообщение и не подтверждают работу будущих модулей.

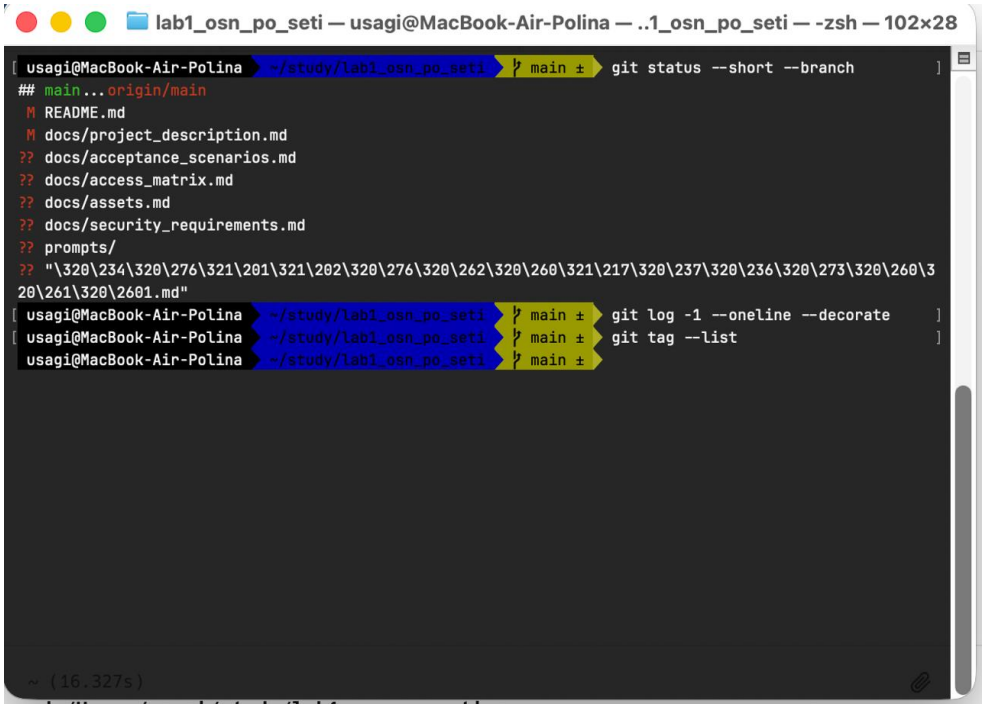


Рис. 2: Исходное состояние репозитория и локальные теги

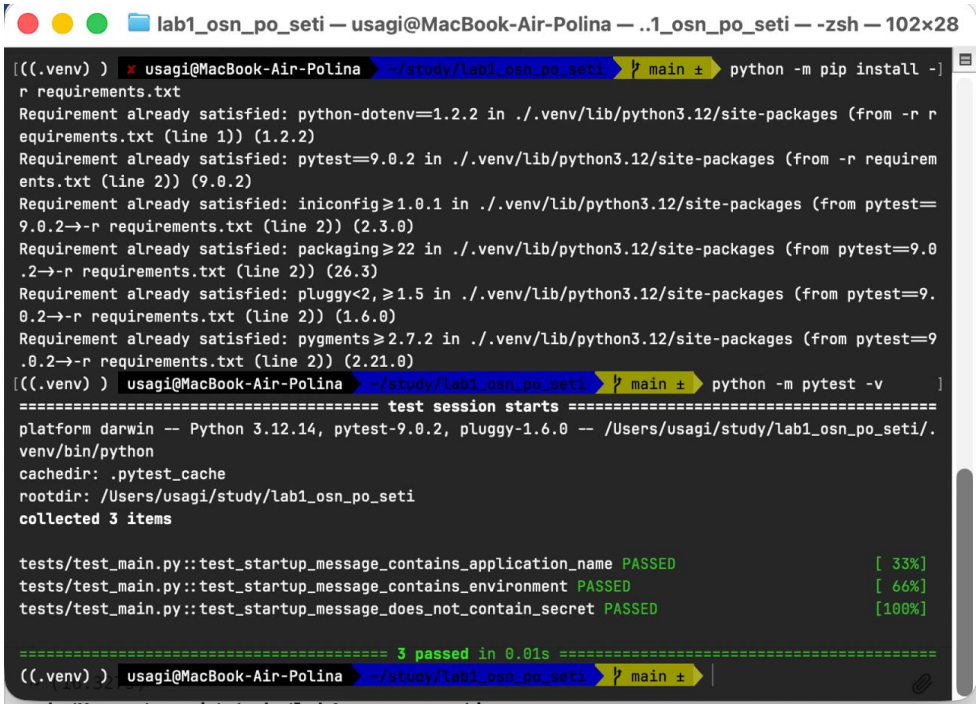
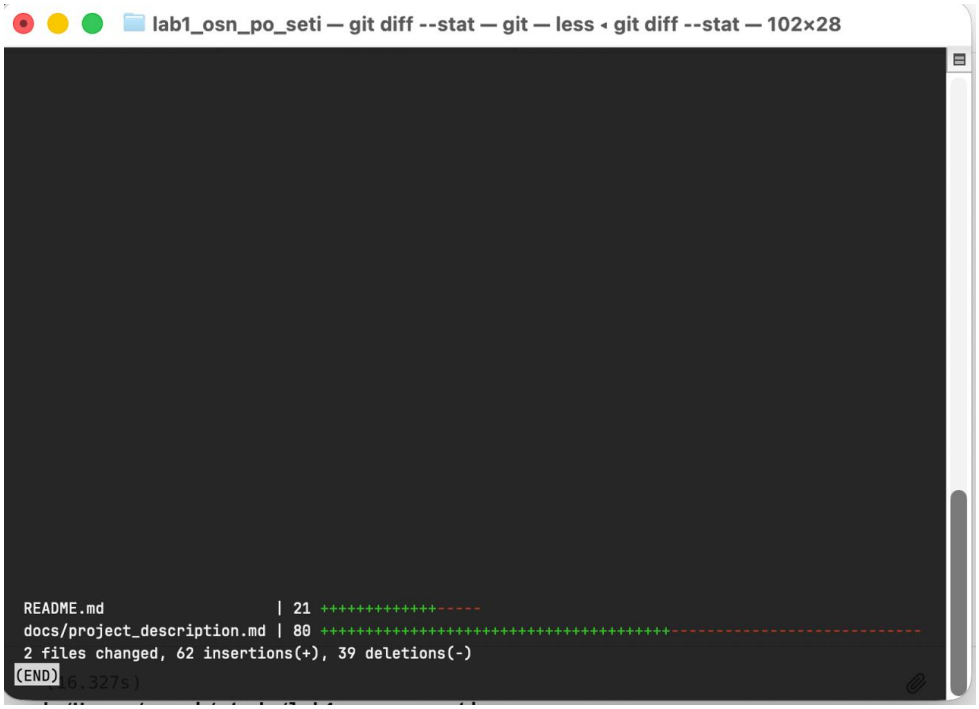


Рис. 3: Выполнение трех исходных тестов

8. Проверка Git

Основной результат лабораторной зафиксирован тегом v0.2 на commit 4026dd7. После дополнительной сверки документы уточнены в commit 93f0769, для него создан тег v0.2.1; существующий тег v0.2 не перемещался. Commit и оба тега отправлены в удаленный репозиторий. Сейчас origin/main указывает на 93f0769, тег v0.2 — на исходный commit

лабораторной, v0.2.1 — на commit с уточнениями. Отчет и снимки хранятся отдельно от проектных файлов.


lab1_osn_po_seti — git diff --stat — git — less ◂ git diff --stat — 102×28
README.md | 21 ++++++++++++-----
docs/project_description.md | 80 ++++++++++++

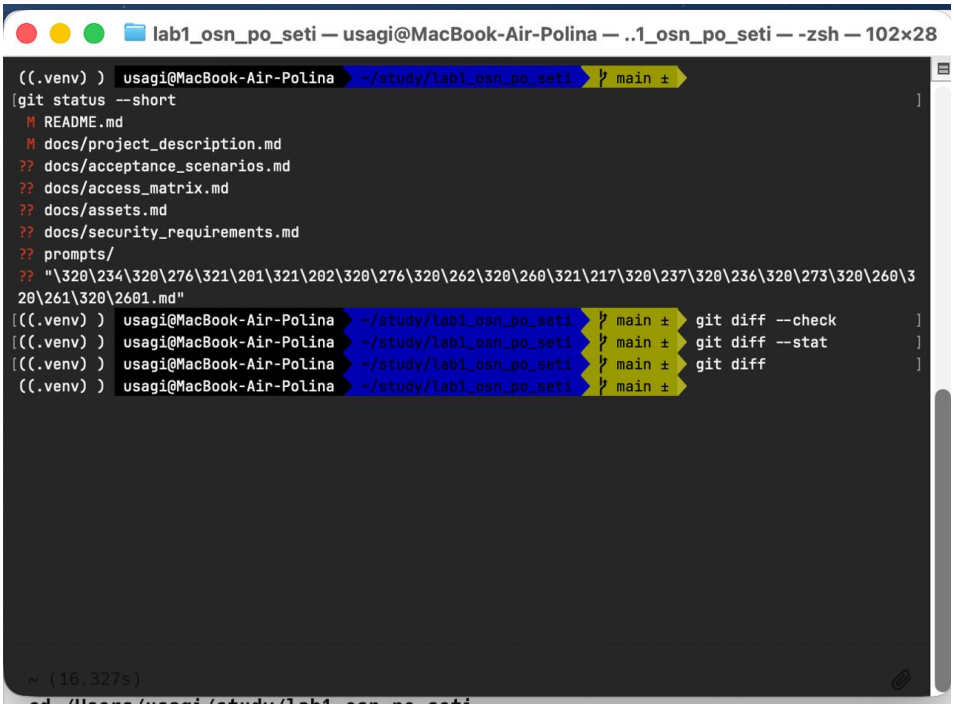


Рис. 6: Проверка рабочего дерева и diff

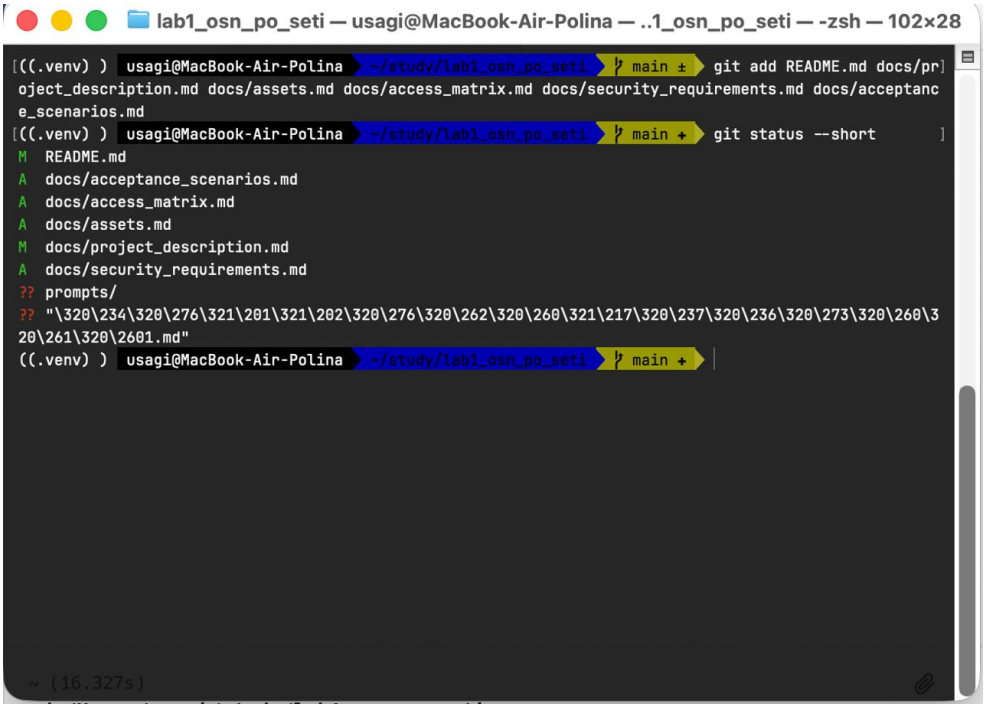
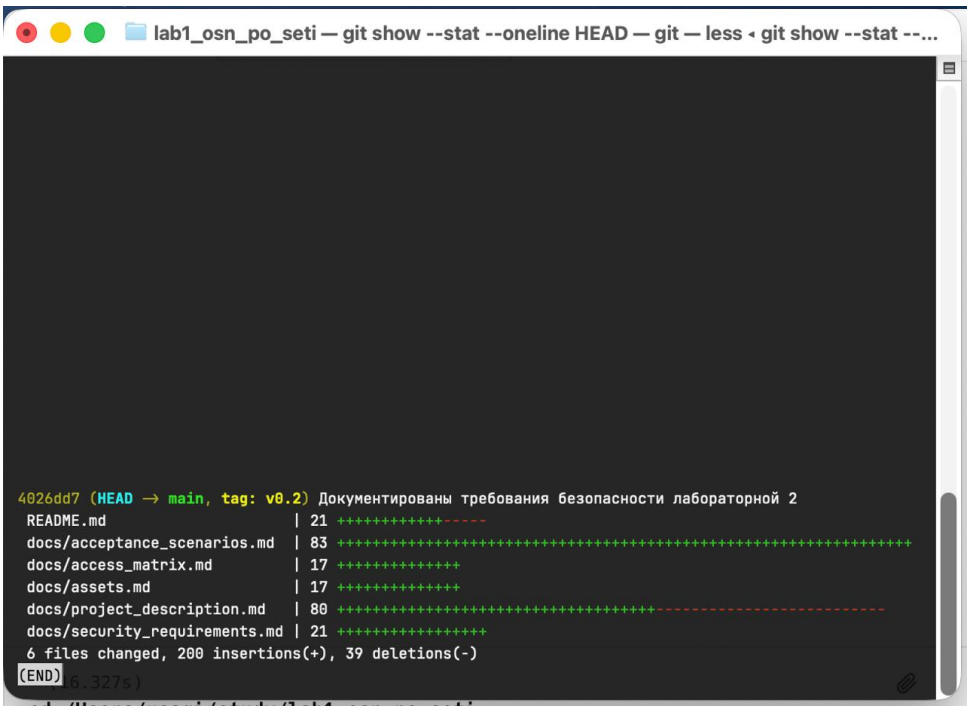


Рис. 7: Подготовка документов к фиксации


lab1_osn_po_seti — git show --stat --oneline HEAD — git — less ◂ git show --stat --...
4026dd7 (HEAD → main, tag: v0.2) Документированы требования безопасности лабораторной 2
README.md | 21 ++++++++++++-----
docs/acceptance_scenarios.md | 83 ++++++++++++

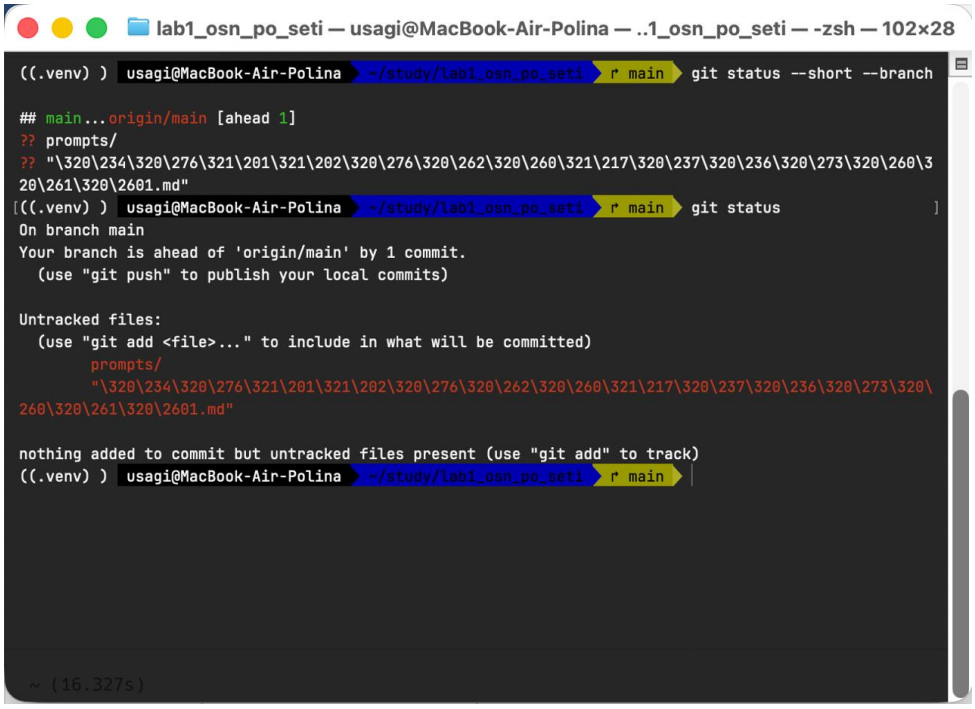


Рис. 10: Состояние Git после commit: остались локальные файлы

9. Ответы на контрольные вопросы

1. Границы показывают, какие компоненты и процессы защищаются проектом, а какие принадлежат внешним системам.
2. Категория группирует похожие данные; актив — объект или ресурс, ценность которого нужно защищать. Актив может объединять несколько категорий.
3. Конфиденциальность нарушается при раскрытии, целостность — при подмене или уничтожении, доступность — когда ресурс нельзя использовать вовремя.
4. Значимость характеризует последствия потери свойства. Риск дополнительно учитывает угрозу, сценарий и вероятность реализации.
5. Максимум скрывает два других значения и различия профилей C/I/A. Поэтому в реестре сохраняются все три оценки и их объяснения.
6. Роль задает набор полномочий; учетная запись относится к конкретному пользователю, которому назначена роль.
7. Роль сама по себе не показывает, какому пользователю принадлежит объект. Водителю разрешены только его поездки.
8. Нет. Администратору предоставляют полномочия, необходимые для его задач; доступ к прикладным данным требует отдельного обоснования.
9. Функциональное требование задает защитное действие системы, нефункциональное — свойство или ограничение ее работы.
10. Они фиксируют правила разработки и сопровождения, например ревью изменений и выполнение тестов до выпуска.
11. Нужны однозначное действие, условия, наблюдаемый критерий и способ проверки.
12. Критерий описывает ожидаемый результат; способ проверки — как получить и оценить этот результат.
13. ID помогает однозначно связывать требование со сценариями, документами и результатами проверки.
14. Функция использует актив; требование задает защитное поведение; проверка сцена-

рия подтверждает соответствие критерию.

15. Позитивный сценарий проверяет разрешенное действие; негативный — отказ запрещенного действия или обработку неверных данных.
16. Отказ в ответе не гарантирует, что данные не были изменены. Поэтому после запроса проверяется состояние записи.
17. Длинное значение может быть предсказуемым. Нужны достаточная случайность и безопасные генерация, хранение и применение.
18. «Сформулировано» означает, что требование записано; «реализовано» — механизм существует; «проверено» — имеется результат фактической проверки.
19. Проверяются состав staged файлов, diff, отсутствие секретов и временных файлов, согласованность документации и результаты применимых тестов.
20. Активы, роли, границы и требования помогают определить нарушителей, угрозы, последствия и оценить риски в следующей лабораторной работе.

10. Вывод

В работе описаны роли и границы системы учета транспорта, данные и активы, предварительные правила доступа, требования безопасности и сценарии их проверки. Текущий код по-прежнему ограничен запуском приложения и проверкой конфигурации. Три имеющихся теста прошли; сценарии будущих функций не выполнялись. Commit с исправлениями и тег v0.2.1 опубликованы в удаленном репозитории; исходный тег v0.2 сохранен.

Список использованных источников

[1] Методические указания «Лабораторная работа № 2. Формирование требований безопасности к программной системе».

[2] OWASP Foundation. Application Security Verification Standard (ASVS), version 5.0.0 [Электронный ресурс]. URL: https://owasp.org/www-project-application-security-verification-standard/ (дата обращения: 15.10.2026).

[3] OWASP Foundation. Authorization Cheat Sheet [Электронный ресурс]. URL: https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html (дата обращения: 15.10.2026).